Government Information Quarterly 42 (2025) 102000

Contents lists available at ScienceDirect

Government Information Quarterly

journal homepage: www.elsevier.com/locate/govinf

Evaluating incident reporting in cybersecurity. From threat detection to policy learning

Simone Busetti *, Francesco Maria Scanni

University of Teramo, Via R. Balzarini 1, 64100 Teramo, Italy

ARTICLE INFO

Keywords:
Cybersecurity
NIS2
Cyber incident
Incident reporting
Policy learning
Realist synthesis

ABSTRACT

The escalating threat of cyber risks has propelled cybersecurity policy to the forefront of governmental agendas worldwide. Incident reporting, a cornerstone of cybersecurity legislation, may facilitate swift responses to cyberattacks and foster a learning process for policy enhancement. Despite its widespread adoption, there are no analyses on its efficacy, implementation, and avenues for improvement. This article provides a theory-based evaluation of incident reporting using the methods of realist synthesis and process tracing. We develop a program theory of incident reporting hypothesizing its dual role as a fire alarm and a catalyst for policy learning. The program theory is tested by drawing upon a range of literature and official documents, supplemented by insights from the Italian context through interviews with key informants. The evaluation reveals mixed findings. While incident reporting effectively serves as a fire alarm, particularly for organizations with limited cybersecurity capacity, challenges persist due to capacity gaps and a reluctance to report incidents. The link between incident reporting and policy learning remains tenuous, with evidence of inertia hindering the implementation of more radical changes. Policy recommendations include streamlining internal communications, combining rapid and in-depth reporting, fostering data-sharing agreements, ensuring dedicated communication of lessons from central cyber actors, and streamlining organizational procedures for implementing changes.

1. Introduction

The exponential growth of cyber risks poses a significant threat to the security of businesses, public administrations, and institutions, making cybersecurity policy a paramount concern for governments (Lewallen, 2021). In response, local authorities (Norris & Mateczun, 2022), national governments (Newmeyer, 2015), and supranational and international institutions (Golden, 2018) are attempting to cope with these evolving dangers.

A rising number of interventions are implemented to enhance cyber resilience, prevent incidents, and develop threat intelligence activities (Conti, Dargahi, & Dehghantanha, 2018): the certification of ICT products and digital service providers (Cadzow, Sanchez, & Baldini, 2018; Kamara, Ronald Leenes, & Stuurman, and Jasper van den Boom., 2020; Khurshid, Alsaaidi, Aslam, & Raza, 2022; Tsvilii, 2021), information sharing among administrations (Luiijf & Klaver, 2015; Pala & Zhuang, 2019; Zibak & Simpson, 2019), audit activities, monitoring, and risk assessments (Dupont, 2019; Mughal, 2018; Onwubiko, 2015), and network security procedures to safeguard data against malware (Badsha, Vakilinia, & Sengupta, 2019; Markopoulou, Papakonstantinou, & de Hert, 2019; Schünemann & Baumann, 2017; Sule, Zennaro, & Thomas, 2021).

Among these tools, incident reporting—the obligation to report incidents to cybersecurity authorities—plays a pivotal role in the architecture of cybersecurity policy in various countries (Christou, 2016; Cram & Mouajou-Kenfack, 2022; Fuster & Jasmontaite, 2020; Santos, 2018; Schmitz-Berndt & Chiara, 2022). It is established in European legislation (NIS1 Directive EU 2016/1148; NIS2 Directive EU 2022/2555), most EU member states (see the NIS directive tool at enisa.europe.eu), the UK (Data Protection Act 2018), Canada (Bill C-262022), and the USA (Cybersecurity Information Sharing Act S.2588/2015), as well as by national and international cybersecurity agencies (ENISA, 2015; NIST, 2012). NIST considers incident reporting "the most important aspect of incident response coordination" (NIST, 2012, p. 45) and ENISA the "cornerstone of European Union cybersecurity legislation" (ENISA, n.d.).

Incident reporting is considered to serve various functions, such as enabling post-incident recovery, limiting damage caused by malware attacks, and allowing the collection of data to improve prevention strategies (Johnson & Chris, 2015; Khurana et al., 2009; Michail, 2020;

* Corresponding author.
E-mail address: sbusetti@unite.it (S. Busetti).

https://doi.org/10.1016/j.giq.2024.102000
Received 16 March 2024; Received in revised form 2 October 2024; Accepted 12 December 2024
Available online 24 December 2024
0740-624X/© 2024 The Authors. Published by Elsevier Inc. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

Sveen, Finn, Sarriegi, Rich, & Gonzalez, 2007). As described in the following, it is the foundation of systemic alerts, the trigger for prompt intervention and the knowledge source for evidence-based organizational and policy change. A formal bureaucratic application of incident reporting would only translate into additional red tape and risk contagion, delayed containment, and greater damage and would not allow adjusting to the most recent threats.

However, despite its widespread adoption and its acknowledged importance, there are no analyses on whether incident reporting works, how it is implemented, or how its effectiveness might be improved. This article addresses this gap by performing a theory-based evaluation applying the method of realist synthesis (Pawson, Greenhalgh, Harvey, & Walshe, 2004). Using literature and official documents, we develop the hypothesis that, to be effective, incident reporting should serve as a *fire alarm* and a tool for *policy learning*. First, it should enable the swift intervention of competent actors, such as computer security incident response teams (CSIRT), mitigating the severity of incidents and alerting other potential targets to prevent further contagion. Second, incident notification should facilitate the systematic collection and translation of information into policy-relevant lessons, enhancing cyber policy based on an expanded knowledge base. The article tests this hypothesis by reviewing a wide array of documental sources and uses the case of Italy to gather first-hand information through interviews with actors involved in the implementation of incident reporting.

The article proceeds as follows. The next section presents the methodology, while the following describes the context of the evolution of cybersecurity policy in Italy. The fourth section outlines the hypothesis of the program theory of incident notification. Finally, the fifth section tests the hypothesis, while the conclusions summarize our findings and provide policy recommendations for improving incident notification.

2. Materials and methods

2.1. Research design

The study employs a 'realist review,' a technique for collecting and synthesizing evidence that is part of the theory-driven approach to policy evaluation (Pawson, 2002; Pawson et al., 2004).

The focus of the review is explanatory; it aims at exploring, testing, and refining the underlying mechanisms explaining why and how an intervention is supposed to work (i.e., its program theory). The program theory typically takes the form of a chain of decision points, a causal process going from interventions to results: 'If we implement incident reporting, then subject x will respond like this, subject y will do this given condition z, and this will ultimately bring about outcome O'. At each stage, the intervention could work as expected or 'misfire,' depending on the reaction of the subjects involved and the contextual features of its implementation. The realist review will 'populate' this program theory with empirical findings and evaluate whether the program works as expected and 'what works for whom, in what circumstances, in what respects, and how' (Pawson et al., 2004, p. v).

In practice, we proceeded in two steps. First, we developed a multistep program theory of incident reporting as follows: A. Design features, B. Detection and reporting, C. Incident response, D. Knowledge translation, E. Learning products (see next section and Fig. 2). This initial program theory was drafted by analyzing legislation, official documents, and parliamentary debates to outline explicitly government expectations about how incident reporting is supposed to work. Second, we used this program theory as a benchmark against which to compare government expectations with the actual operation of the program. To do this, the review process entailed searching for evidence (academic and grey literature and interviews) to test and qualify each step of the program theory, verifying the operation of its underlying assumptions and discovering weak points, blockages, or effective implementation solutions.

In collecting the empirical material, we used process tracing—a method to appraise the strength of the evidence collected and increase the reliability of within-case inferences (Beach & Pedersen, 2019; Brady & Collier, 2010). We used process tracing in its theory-testing form (Beach & Pedersen, 2019); we identified possible pieces of evidence for each step (coded in the text by step and evidence number, e.g. E.a.3), discussed their probative values (i.e., how they increase the likelihood of the hypothesized step), and ultimately proceeded to collect evidence in fieldwork (Beach & Pedersen, 2019). Appendix A explains the process-tracing method in depth: the evidence appraisal, the different pieces of evidence, their probative values, and whether that evidence was found (or not) in the fieldwork.

2.2. Case selection

Cybersecurity policy is a relevant context in which to investigate the acquisition and use of information. Cybersecurity is characterized by recurrent crises and evolving attack methodologies (Mijwil, Unogwu, Filali, Bala, & Al-Shahwani, 2023) as well as daily threats that may produce continual information gathering and prompt administrations to update and change to enhance their resilience. In addition, incident reporting is an institutionalized tool for knowledge acquisition, where organizations are mandated by law to gather information, analyze it, and communicate it to the authority in charge. Hence, it is a crucial case (Gerring, 2007), one where it should be most likely to observe if and how the acquisition of knowledge leads to lessons and policy changes.

Given the paucity of available research, we complemented the review of secondary sources and existing studies with primary data drawn from the case of Italy. An in-depth case study allowed us to diversify our data and obtain evidence about informal procedures and actual implementation processes. Italy can be considered a representative case of compliance in the implementation of EU NIS directives and even anticipated some of the tougher prescriptions contained in NIS2. The country has a formalized procedure for incident reporting, a clear definition of the sectors subject to reporting, and a unique point of contact in the national CSIRT (see section 3). This represents how incident reporting is organized in most countries, so the present evaluation may provide policy recommendations valid outside the Italian context.

2.3. Data

The research draws from a diverse range of sources: academic literature, European and Italian legislative statutes, press releases, reports from major Italian cybersecurity organizations, statements from relevant actors, stenographic records of parliamentary debates, and 11 semi-structured interviews with key informants. Although realist synthesis is mainly a method for integrating secondary evidence, the interviews were necessary to identify informal processes, contextual factors, and actors' strategies, often absent in official documents. Table 1 provides a breakdown of the type and number of sources reviewed for this research.[1]

[1] The review process was conducted through keyword searches on Google Scholar for the academic literature and Open Grey for the grey literature. Concerning the academic literature, we initially developed search queries by associating "cybersecurity" with "incident notification" and "incident reporting." This approach helped to contextualise the research, focusing on the application of incident reporting within the field of cybersecurity. Then, we combined the terms "cybersecurity" and "reporting/notification" with additional keywords including "policy", "learning," "strategies," "CSIRT," "ACN," "NIS1," "NIS2," "ENISA," "perimeter," "alert," "program theory," "detection," "knowledge," "prevention," "mitigation," and "containment." This process resulted in an initial yield of 869 resources, comprising 647 articles, 207 conference papers, and 15 books. These resources were then selected based on the reading of abstracts, leading to the inclusion of 104 journal articles, 9 books, and 15 conference papers that were read in full.

Table 1
Breakdown of sources.

Consulted documents	*N*
Academic literature (read in full)	- 104 journal articles - 9 books - 15 conference papers
European legislative statutes	- NIS 1; NIS 2; EU Cybersecurity Strategy; Cyber Resilience Act; Cybersecurity Act; Cyber Solidarity Act; Joint Cyber Unit; Recovery and Resilience Plan (Next Generation EU)
National legislative statutes	- UK: Data Protection Act 2018; Cyber Security Information Sharing Partnership 2013; The Network and Information Systems Regulations n.506 of 2018 - Germany: ITSiG 2.0 of 2021; 2nd BSI KritisVÄndV of 2022 - France: Decree 384 of 2018; Act 133 of 2018 - Canada: Bill C-26 - Spain: Royal Decree-Law 12 of 2018 - Portugal: Portuguese Cybersecurity Act of 2018 - USA: Cybersecurity Information Sharing Act S.2588 of 2015; Executive Order 14028 of 2021; Strengthening American Cybersecurity Act of 2022 - Italy: D.L. No. 82 of June 14, 2021; DPCM No. 105 of 2019; DPCM No. 131 of 2020; DPCM No. 81 of 2021; DPCM No. 198 of 2021; DPCM No. 4 of 2022
Stenographic reports	- 12 stenographic reports of parliamentary debates (7 from the Chamber of Deputy and 5 from the Senate)
News and reports from cybersecurity agencies	- 6 ACN reports, 2022–2026 National Cybersecurity Strategy document, 2022–2026 Implementation Plan and 2022 Annual Report, 5 AGID report, Three-year plan 2020–2022 and 2022–2024 - 5 NIST report and frameworks - 22 ENISA reports, ENISA Strategy 2016–2020, and 2023–2025 document - 25 Bulletins and 30 CSIRT Alerts
Press statements	- 16 interviews given by relevant actors: ACN, CSIRT, ministries, council presidency
Key informant interviews	- 11 interviews with executives of selected public administrations and members of the ACN

Source: created by the authors.

The interviews were conducted in person or online and lasted an average of one hour. Interviews were not recorded because of the sensitivity of the topic. We interviewed members of the Italian National Agency for Cybersecurity (ACN), two target administrations potentially using the reporting procedure, and a major IT provider present in more than 100 countries and managing assets legally subject to incident reporting. The two public administrations were selected to maximize the variance of information about the reporting procedure. One is an Italian university that used voluntary incident reporting and interacted with the CSIRT after some major cyber-incidents. The university portrays the typical public administration where cybersecurity is not a core task, and the cybersecurity staff overlaps with the ordinary IT office. The second administration is a militarized law enforcement agency with core cybersecurity functions and a high cyber capacity and subject to mandatory incident reporting. This latter organization offers the possibility of observing good practices that can suggest improvements to the implementation of reporting. The inclusion of these diverse cases helps represent the variety of public administrations and provides a tougher test of the program theory. Finally, the IT provider helped in understanding how the interface between target administration and the supply chain impacts the working of incident reporting. Appendix B details the interview protocol and the list of interviewees.

2.4. Limitations of this study

Cybersecurity inevitably involves intelligence information and institutional and individual security. Searching for evidence proved challenging due to informants' reluctance to disclose information.

Further, as with most studies on policy learning, we acknowledge the possibility of omissions of cases of inertia (i.e., information collected but not used for changing the policy) and the overrepresentation of cases of successful learning (see Busetti & Righettini, 2023, for a discussion of this problem).

3. Cybersecurity policy and incident reporting in Italy

Following the implementation of the NIS1 Directive, the landscape of Italian cybersecurity policy underwent a rapid evolution, as illustrated in Fig. 1. Legislative Decree 65 of 2018 played a pivotal role in this transformation. The decree introduced incident reporting for all organizations whose incidents may produce "a major impact on the continuity of essential services" (Leg. D. 652,018 Art. 12) and established the national CSIRT. Consolidating the responsibilities of the existing National Computer Emergency Response Team (CERT) and CERT-PA (a dedicated CERT for public administrations), the CSIRT became the unified point of contact for reporting cyber-incidents.

In 2019, the government further fortified the cybersecurity framework with the approval of Decree 105 establishing the Perimeter of National Cyber Security (PNCS). This included a broad spectrum of public and private actors involved in essential services: home affairs, defense, space and aerospace, energy, telecommunications, economy and finance, transportation, digital services, and critical technologies. Members of the PNCS were mandated to maintain an annually updated list of ICT assets (DPCM 1312020) and to report to the CSIRT any incidents affecting the listed assets. In 2022, Decree 115 extended the obligation for incident reporting, making it also mandatory for all incidents involving PNCS actors, regardless of whether those incidents involved the listed ICT assets.

Finally, a pivotal moment in 2021 saw a general restructuring of cybersecurity governance with the establishment of the National Agency for Cybersecurity (ACN). Integrated with and expanding the CSIRT, the ACN takes on a coordination role, formulates the National Cybersecurity Strategy (currently spanning 2022–2026) (ACN, 2022a) and—together with the CSIRT—is tasked with monitoring activities and early warnings connected to incident notification.

At present, incident reporting is mandatory for all actors included in the PNCS and voluntary for organizations outside it. Following the EU NIS2 directive, according to Italian law, PNCS actors are required to perform both 'rapid' and 'in-depth' incident reporting. The rapid notification is mandated within 1 to 6 h after detection, depending on the severity of the attack. The in-depth report is due 30 days after the incident; the organization will produce an in-depth report outlining all relevant information about the incident, such as the impact on ICT assets and the actions of mitigation and recovery implemented (DPCM 812021, art. 3).

4. How does incident reporting work? A program theory

Incident reporting only entails transmitting information from the organizations subject to incidents to a designated point of contact. Such notification does not improve cybersecurity per se, and its use may simply be limited to monitoring threats for accountability reasons. As reconstructed through the analysis of official government documents, incident notification is supposed to work through two connected processes for improving cybersecurity: 'fire alarm' and 'policy learning.'

First, incident reporting may work as an alarm by signaling cyber threats to a competent authority (e.g., the CSIRT) that can implement mitigation actions. This communication will allow the CSIRT to support the targeted administration and alert other organizations to avoid the risk of contagion. Second, reporting may work as an institutionalized tool for knowledge acquisition. After post-incident recovery, information about incidents may provide lessons for both the targeted administration and the public authority tasked with cybersecurity. The

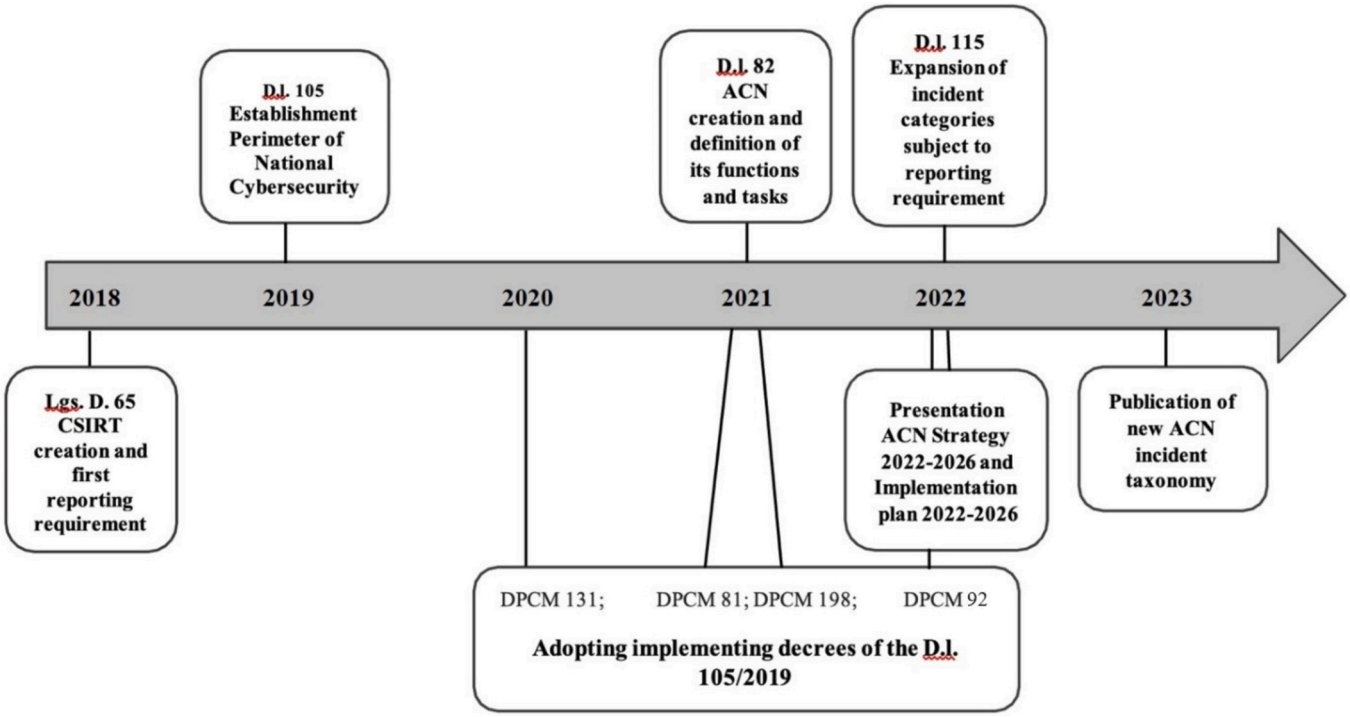

Fig. 1. The evolution of Italian cybersecurity. Source: created by the authors.

reporting may point to weaknesses and suggest the need for updated technology and procedures. Shortly put, reporting may trigger a learning process, with the information transmitted through reporting focusing the attention of organizational actors and policymakers and providing lessons for contributing to organizational and policy change. In theory, incident reporting may work as an institutional learning arrangement triggering both organization and policy learning (Busenberg, 2001; Sagan, 1993).

This double logic of incident reporting is implicit in cybersecurity policy worldwide. The guidelines provided by the US National Institute of Standards and Technology (NIST, 2012, 2018) suggest that incident detection and reporting should be followed by containment, eradication, and recovery activities by the CSIRT (the fire alarm) and post-incident activities to learn from the incident and improve and adjust incident response policies, plans, and procedures (the policy learning) (see also Michail, 2020). Similarly, ENISA underscores this dual function of incident mitigation and post-incident data aggregation and analysis (ENISA website – Incident Reporting; ENISA, 2013, 2014, 2015, 2022a); a logic shared by various European countries, where reporting is deemed to facilitate not only effective incident management but also post-incident learning, thereby bolstering organizational resilience (CREST, 2013; HM Government UK, 2022), and allow update of the overall cyber threat landscape and guidance for operators (Deutscher Bundestag, 2021).

In the case of Italy, this double logic is clearly stated in government documents, ACN and CSIRT statutes, and strategies. When an organization reports an incident, the CSIRT can be directly in charge of the mitigation response, and the agency is tasked with issuing alerts and early warnings for the benefit of other potential targets. Concerning the learning process, Legislative Decree 65 of 2018 established that the CSIRT should also provide for dynamic and post-incident analyses of the nature and cause of the incident and the determination of its initial cause (e.g., the vulnerability exploited) to disseminate countermeasures (CSIRT, 2023). Further, the ACN is supposed to perform "specialised technical analysis on malware, cyber threat actors, and the contextualization of attacks" (ACN website, n.d.).

To work as such, however, incident reporting should trigger specific behavioral and organizational responses that are far from obvious. Major assumptions about the capacity of actors, their actions, and the optimal use of information are left implicit and need testing. To this end, we developed a multi-step program theory illustrated in Fig. 2 and tested in the next section.

The procedure for incident notification should be designed to allow for the effective detection and reporting of relevant incidents by including significant threats and relevant target organizations and allowing the transmission of useful information (Step A). Then, targeted actors must have the capacity to detect incidents, evaluate their significance, and promptly report to the institution in charge (Step B). In response to the reporting, the cybersecurity agency, CSIRT, or CERT must first deploy mitigation strategies and bring the systems back on track (Step C). The integrity of these three steps is vital for incident reporting to be an effective tool for immediate response, damage containment and mitigation (Outcome 1) and lays the foundation for knowledge acquisition about incidents.

Finally, to generate organizational and policy learning, the information collected should then be translated into lessons (i.e., propositions having policy implications) (Step D), and these lessons are implemented into learning products (i.e., new strategies, policies, programs and tools, or adjustments to, expansions of, or maintenance of existing procedures and policy) (Step E) (Gerlak & Heikkila, 2011; Heikkila & Gerlak, 2013).

5. Evaluating incident reporting

This section tests the program theory step by step to see whether it works as expected, in which contexts, with which actors' responses and capacity, and whether there are barriers to its working. Our prior assumption when entering this research was that the 'fire alarm' was likely congruent with the expectations since it entails short-term responses to an immediate threat and actions are mandatory and sanctioned by law. Instead, we expected policy learning to be harder to materialize since it is long-term and the information collected may be used ineffectively.

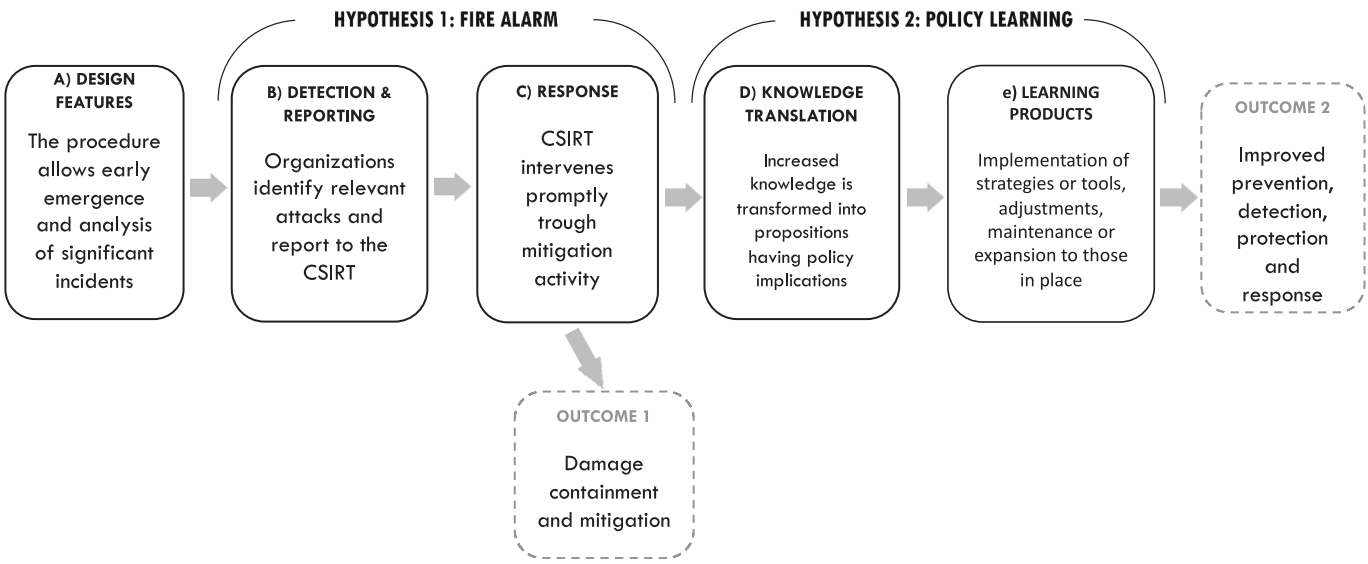

Fig. 2. *A program theory for incident reporting.* Source: created by the authors.

5.1. Step A: Design features

The first step to be tested regards whether incident reporting is designed to be an effective tool for information transmission, mitigation, and learning. To do so, the procedure must be mandatory for those actors whose incidents may impair essential services (5.1.1), cover those incidents that produce significant harm (5.1.2), and ensure the quality of the knowledge transmitted (i.e., providing incident information that is relevant and timely) (5.1.3).

5.1.1. Organizations subject to reporting

To maximize effectiveness, incident reporting should be designed to include virtually all actors who manage essential services or could cause disruption to such services. The evolution of cybersecurity policy in the EU and Italy has progressed in this direction.

In 2020, the Impact Assessment of the European Commission (EU Commission, 2020) had highlighted the insufficient coverage of essential sectors, the negative impact on the security of essential services, and the need to reduce inconsistencies among sectors through the extension of incident reporting (E.a3) (EU Commission, 2020, p. 1). Accordingly, NIS2 broadened the critical sectors and included, among others, digital providers, health, and services of food production, processing, and distribution. While NIS1 left the choice of relevant actors to individual member states, the new directive directly identifies the actors subject to the reporting requirement; it distinguishes between *essential* and *important* entities, depending on how critical they are for their sector or the type of service they provide. From the perspective of incident reporting, essential entities are subject to more severe sanctions in case of non-compliance with the reporting obligations (NIS2 art. 34).

Regarding the organizations subject to reporting, observers cautioned about the exclusion of SMEs in NIS1 (Atkins & Lawson, 2021; Crick, Davenport, Irons, & Prickett, 2019), pointing to the possibility that incidents in the supply chain might spread to critical infrastructure (Matassa, 2022). Following these remarks, NIS2 mandated that national cybersecurity strategies address cybersecurity in the supply chain for ICT products and ICT services used by entities for the provision of their service (NIS2, Article 7) (E.a3). In Italy, a 2021 government regulation (DPCM 81 of 2021) provided guidelines for risk analysis and mitigation, highlighting the need for PNCS actors to initiate control processes to identify, assess, and manage supply chain–related risks to ensure more comprehensive incident information.

However, according to ENISA, the extension of controls to supply chain actors is still largely deficient (ENISA, 2023). As testified in our interviews, there is profound uncertainty about when supply chain actors should be subject to incident notification, with interpretations done case-by-case based on an appraisal of the legal and reputational risks connected to reporting or failing to report (Interview 11).

5.1.2. Identification of significant incidents

The procedure should include a clear definition of 'significant incidents,' one that allows target administrations to understand what incidents are to be reported and reduce underreporting.

In the NIS1 Directive, there was no such definition. NIS2 clarified that an incident is significant when it "has caused or is capable of causing severe operational disruption of the services or financial loss for the entity concerned" and "it has affected or is capable of affecting other natural or legal persons by causing considerable material or non-material damage" (NIS2, art. 23) (E.a1). Critics warn that "the NIS 2 Directive remains silent on guidance as to when an incident that has not resulted in harm is nevertheless reportable" (Schmitz-Berndt, 2023, p. 8), a gap that highlights the absence of a standard measure and the possibility of discretion in determining which incidents to report. In Italian regulations, the significance of an incident is linked to the disruption of the continuity of services provided, and its determination follows a series of parameters such as the number of affected users, the duration of the incident, the geographical spread, and the impact on economic and social activities (DPCM 812021 art. 3) (E.a1).

In our interviews with the law enforcement agency, the interviewees testified that the definition was clear, and there was no doubt in assessing the significance of incidents and which incidents were subject to reporting (Interview 9) (E.a1).

Instead, the university, subject to voluntary reporting, said they communicated to the CSIRT only those incidents that created disruptions to their services that were not solvable in-house, without reference to the legal definition, the magnitude of the incident, or the likelihood of contagion (Interviews 1, 2). These two cases suggest there is heterogeneity in the types of incidents reported, and, more importantly, administrations not subject to an obligation may use reporting only as an alarm to call for support when the incident becomes unmanageable.

5.1.3. The quality of information

The effectiveness of reporting also depends on whether it is designed to allow for timely and truly informative reports. Looking at the EU, improvements have materialized in terms of the knowledge transmitted, the transmission procedures, and the timing of communication.

Regarding the latter, in contrast with NIS1—where notification had

to be made "without undue delay" (NIS1 art. 14)—NIS2 (art. 102) provides for a more accurate definition of reporting timing and content for essential and important entities; they need to produce an early warning within 24 h of becoming aware of the incident (containing only the information strictly necessary to justify the request for assistance), a reporting within 72 h updating the early warning information if necessary, and finally a comprehensive report within one month of the incident report (E.a8). In Italy, members of the PNCS are subject to a tighter timing for the first alert, which is to communicate within 1–6 h instead of 24 (E.a8).

The different timing in notifications should strike the right balance between the need for immediate intervention to mitigate the incident and in-depth reporting that includes valuable knowledge and lessons (NIS2, art. 102). Drawing from our interviews, there is a confirmation that communication with CSIRT is easy and fast (Interviews 1, 2, 3, 7, 8, 9) (E. a9), while the 30-day in-depth report is evaluated positively in terms of content; it is considered a potential resource for sharing detailed information to foster learning by other administrations on the dynamics of the attack and related mitigation measures (Interview 8) (E. a5).

Two caveats are in order. First, the lack of a clear procedure for reporting may produce discretion and inconsistency in communications. Annual Report Telecom Security Incidents 2021 (ENISA, 2022b, p. 4) highlighted that the same incident related to 'over-the-top' (OTT) services was reported three times by three different member states in three different ways (ENISA, 2022b, p. 4) (E.a6). Considering the more precise guidance on reporting provided by ENISA (see the Technical Guideline on Incident Reporting, ENISA, 2014) compared to the ones provided nationally (for Italy, see CSIRT website, n.d.), it is reasonable to also expect inconsistencies in reported incidents within the national context.

Second, the relevance of the information collected needs to be put into perspective. As testified in our interviews (Interviews 7, 8, 9), incident reporting is one among several sources of cybersecurity information (see also ISPI, 2022), together with proactive threat intelligence and communications with security agencies in other countries (E.a7). In this respect, incident reports may provide information that escaped the intelligence activity of national cybersecurity actors, and, regarding the one-month in-depth report, information otherwise unavailable about the response capacity of the administrations and what mitigation strategies were successful.

5.2. Step B: Detection and reporting

The second step of the program theory depends on organizations actually reporting cyber-incidents. For this to occur, they must have enough capacity to detect the incident, assess its severity, and report the event properly to the CSIRT. Subtly, they also must *want* to share their data with the CSIRT.

5.2.1. Capacity gaps

Capacity deficits in technology, staff, and skills can be a major problem for the effectiveness of incident notification. In the case of Italy, government regulation 81/2021 (DPCM 81/2021) establishes a set of minimum-security requirements to ensure the identification of incidents, including the need to elaborate dedicated monitoring activities (E.b5). In practice, organizations subject to incident reporting show wide heterogeneity in their cybersecurity capacity.

In the Italian context, part of the literature (Rossa, 2023) and reports from national government agencies (CERT-AGID, 2020) highlight a general deficiency in public administrations and organizations managing critical infrastructure. The 2020 monitoring by the government agency for digital technology (AGID) revealed that 67 % of the domains and portals evaluated had security issues (CERT-AGID, 2020). In 2021, the former minister for technological innovation and digital transition estimated that 95 % of public administrations in Italy had servers at cyber risk (Colao, 2021) (E.b2). According to interviews with the ACN, there is a high disparity in the level of cyber preparedness of Italian public and private organizations, with the banking and energy sectors showing high capacity, whereas others, like transportation and particularly healthcare, experiencing major gaps (Interview 5; E.b1). These differences are consistent with the international literature (see Atkins & Lawson, 2021).

The Italian public sector also has a long-standing problem in attracting and retaining highly skilled staff (Battisti, 2020), a problem confirmed in our interviews regarding cybersecurity as well (Interview 8) (E.b1). In 2022, the coordinator of the Technological Innovation and Digitalization Committee of State-Regions Conference pointed to the lack of qualified personnel in Italian public administrations (Fioroni, 2022) (E.b1), a professional gap that for the cyber-defense of critical infrastructures is estimated to be between 30 and 40 thousand experts (Baldoni, 2022a) (E.b1).

Finally, there are gaps in skills and training, effectively illustrated in our interviews with the law enforcement agency, an administration exhibiting high levels of capacity in cybersecurity. The agency has implemented wide-ranging training activities for all personnel, including general training in their in-house academy, dedicated training for high-level officials (considered to be sensitive targets), and simulation-based training where staff are subjected to simulated attacks and their actions are evaluated and serve as a base for targeted training (E.b6). This effort is certainly unavailable for ordinary organizations. Similarly, the agency has a dedicated security operation center (SOC) tasked with proactive defense; it engages in constant threat intelligence to recognize early threats and has access to the same sources of information as ACN and CSIRT (E.b5). In contrast, in most Italian public administrations, cybersecurity is only one (not necessarily the core one) of the responsibilities of the ordinary IT office (Interviews 1, 2, and 3) (E. b1).

A worldwide hacker attack deployed in February 2023 offers proof of how capacity gaps may impair the detection of incidents. The attack consisted of exploiting a vulnerability by releasing ransomware aimed at executing arbitrary commands on target devices (RCEs), affecting several Italian servers managed through VMware ESXi technology. The Italian government issued an official statement tracing the causes of the incident precisely to the inertia exhibited by Italian public administrations in updating their systems. Indeed, the ACN had identified those risks as early as February 2021 and alerted these administrations two years before the attack (Presidency of the Council, 2023) (E.b1).

5.2.2. Internal communication

Although incident notification is a procedure for passing information to actors outside the target organization, the transmission of information starts within the organization. The efficacy of this internal chain of communication between staff and cybersecurity teams is paramount for effective reporting (NIST, 2012). Organizations need to ensure that all staff communicate any incident or suspicious activity to the internal IT service or SOC, which will then evaluate the incident and communicate it to the national actors tasked with cybersecurity, hence complying with the reporting obligation. However, a 2022 global survey conducted by Forrester Analytics revealed that 98 % of non-IT staff had experienced a communication issue regarding IT security and that the inability to communicate or incorrect communications led to cybersecurity incidents in 62 % of the surveyed companies (Forrester Analytics, 2022) (E.b3).

To avoid underreporting, the interviewed law enforcement agency implemented an automatic widget in Microsoft Outlook so that all staff simply need to click on a suspect email to send it to the SOC for screening (Interview 8, 9, 10) (E.b3). This device is a change in the choice architecture that reduces sludge (Thaler & Sunstein, 2021), that is, it makes it easy to communicate with the SOC and reduces frictions that hamper reporting. This is very important since internal communication is not only the first step in incident reporting; it also has a special informative value: threats that get to staff are those that escape the routine

protection systems of the organization (e.g., the firewall) and, hence, the ones conveying useful information about vulnerabilities.

However, the implementation of such technologies is an example of a proactive effort that—against the capacity gaps highlighted in 5.2.1—could not be expected by other administrations, where staff receiving a suspicious email may incur substantive work if they want to communicate with their IT office (i.e., finding the responsible office and procedure, their email or phone number, and then communicating the threat) (Interviews 1, 2, 3).

5.2.3. Reluctance

The willingness of the concerned administrations to report cyber events is another condition to ensure that incident notification works properly. This willingness—and the necessary collaboration and information sharing with the CSIRT—should not be taken for granted. Reluctance to report cyber-incidents due to reputational concerns has been examined in the literature (Correia-Hopkins, 2024; Sangari, 2022) and confirmed by empirical studies in various countries, such as the USA (Sangari, 2022), the UK (Correia, 2022), and Australia (Morgan et al., 2016). Additionally, the Cybersecurity Disasters Survey Incident Reporting & Disclosure study (Keeper Security, 2023), in which 400 interviews were conducted with IT leaders in North America and Europe, highlighted serious deficiencies in incident reporting, with 48 % of respondents admitting to not reporting a significant incident, the majority of whom (79 %) cited fear of repercussions and reputational concerns for the organization (E.b8).

The impact assessment by the EU Commission reported that one of the obstacles to NIS1 implementation across member states was their hesitation in imposing sanctions on organizations that failed to report incidents (EU Commission, 2020, pp. 14–15), implying that the lack of reporting was a much larger phenomenon than the official number of sanctions (E.b8).

In Italy, in a speech delivered at the Mind4Future event, the ACN's new director, Bruno Frattasi, precisely admitted:

> We receive data on cyberattacks affecting Italian businesses and government agencies every day. Still, there is a hidden component that we are unaware of for various reasons. There are a variety of causes for this, but one of them is the unwillingness to admit that one has been attacked because of fear of ruining their reputation and showing weakness. (Frattasi, 2023) (E.b8).

This was also directly confirmed in our interview with an ACN public official: "Many companies prefer not to report incidents but resolve attacks internally because of reputational issues" (Interview 6) (E.b8).

5.3. Step C: Incident response

The third step involves how the actors receiving the notification—typically, the CSIRT—respond to reporting. The success of their involvement depends on their capacity to gather the necessary information and elaborate and implement a response. These activities are considered central in the literature (see West-Brown et al., 1998) and in guidelines provided by international agencies (ENISA, 2006, pp. 66–67; NIST, 2004). In the following subsections, we present some data about the Italian case.

5.3.1. Response capacity

The 2022 ACN Annual Report to Parliament revealed that

> following specific reporting, CSIRT Italia processed 10,249 communications, subjected to triage and correlated with the outcomes of internal monitoring activities, which resulted in the opening of 337 'files', i.e., events with potential criticality profiles that were subjected to in-depth analysis and management. (ACN, 2022c, p. 23) (E.c1).

CSIRT response activity has also been widely confirmed in all major attacks in Italy. In 2022, during a parliamentary inquiry on cyberattacks on healthcare facilities, the former minister of public administration testified about "containment activities, attack analysis, and restoration of essential services" implemented by the CSIRT (Brunetta, 2022) (E.c1). Similarly, the present ACN director repeatedly testified about the intervention of the CSIRT in virtually any large incidents that gained media attention in the country, including a major attack that affected several ministries in February 2023 and another that struck Trenitalia, the national railway company (Frattasi, 2023) (E.c1).

These data do not tell us whether the CSIRT effectively responds to all relevant requests after triage or, instead, whether notifications overload the team and the quality of CSIRT mitigation drops. Some indirect evidence regarding the capacity of the CSIRT may consider the adequacy of its staff, which, as put by ACN Deputy Director Nunzia Ciardi (2023), is a necessary condition for a proper response. In this respect, in 2022, the former ACN director lamented that in the case of multiple attacks (a so-called 0-day attack), relying solely on the CSIRT would be impossible (Baldoni, 2022a) (E.c4)—hence the request to increase the personnel of the CSIRT and ACN from 100 to 300 employees (Baldoni, 2022c) (E.c4). In 2023, the ACN hired 60 technical staff, including 15 coordinators for "cyber security triage operator," 15 for "digital forensic and incident response specialist," 10 coordinators for the functions of "security and threat analyst"; 5 coordinators for the functions of "red team operator," and 5 coordinators for the functions of "data collection and analysis" (E.c4). These data point to a former staff deficit that the ACN is currently working to address.

5.3.2. Technical skills

Concerning technical skills, the effectiveness of the Italian CSIRT received several confirmations. An unexpected piece of evidence comes from the hacker group KillNET. The group initiated a 'total attack' against several Italian institutions on May 29 and 30, 2022 (including the CSIRT's own portal). Two days later, the same hacker group released a statement on Telegram praising the CSIRT for thwarting all attempted attacks:

> Italian CSIRT, the specialists working in this organization are excellent. I have carried out thousands of attacks on such organizations, even Cyberpol does not have such a system to filter millions of requests. At the moment I see that these guys are good professionals! (Rai News, 2022) (E.c3).

Probably regarding the same attack, the former ACN director further highlighted the effectiveness of the CSIRT's protection systems by stating: "We recently suffered a DDoS attack by Russian hackers. It lasted sixteen hours—they could not take our systems offline for not even a second. It was a coordinated, structured attack that we did not underestimate" (Baldoni, 2022e) (E.c3). Notice also that the CSIRT is involved in constant training activities, for instance, in the Cyber Europe 2022 initiative promoted by ENISA (ACN, 2022b) (E.c9).

5.3.3. Quality of information

Another prerequisite for the effectiveness of CSIRT response concerns the capacity to extract relevant information when the attack is reported so that tailored and timely mitigation measures can be enacted. This issue is connected with the target organization's capacity, reluctance to disclose information, and ease of communicating incidents and sharing information.

In this latter respect, the CSIRT has issued specific guidelines about reporting criteria for targeted administrations (CSIRT website, n.d.) (E.c2). The CSIRT's online portal also offers an online reporting service with standardized options for different categories of reporting administrations (within and outside the PNCS).

In addition to ordinary reporting, the ACN established bilateral agreements that expanded the quality and quantity of information sharing and allowed direct access to data regarding the attacks. This occurred in 2022 with an agreement between ACN and the Bank of Italy

(ACN, 2022d) and that between ACN and the Chamber of Deputies, one house of the Italian parliament (ACN, 2023) (E.c2). These collaborations confirm, on the one hand, that the actions of the ACN and CSIRT can be more effective if additional information about the attacks can be obtained beyond the legal requirements and the basic data transmitted through the reporting procedure (E.c2). On the other hand, given the voluntary nature of these collaborations, it may be further confirmation that the willingness of organizations to share information fully and collaborate with the CSIRT may vary among actors (E.b8).

5.4. Step D: Knowledge translation

The fourth step in the program theory regards the long-term learning impact of incident reporting: if and how new information is elaborated into lessons, that is, propositions having policy implications for reforming or maintaining cybersecurity tools. Indeed, only after thoroughly analyzing the types and scope of incidents is it possible to develop strategies for updating objectives and programs (Azmi, Tibben, & Win, 2018). Knowledge translation may be difficult to observe; it is often tacit, rests on informal discussion, and may happen implicitly during incident responses. However, we looked for two kinds of evidence for knowledge translation: the presence of formalized post-incident analysis and evaluative judgments after the incident.

Although often implicit, knowledge translation may be institutionalized through formal procedures for discussing, processing, and analyzing the information acquired from incident notification and incident response. Testimony of processing data activities was provided by a member of the ACN during the 2023 Italian Conference on Cybersecurity (ITASEC), highlighting that the CSIRT and ACN routinely engage in "post-mortem analyses" aimed at "improving the organization's security posture; lessons learned during all previous phases are applied to highlight institutional and management limitations and improve preparedness for future incident management" (Interview 6) (E.d2).

We also found confirmation of routine post-incident analyses in the interviewed administrations. For example, in the case of the law enforcement agency, the widget for suspected emails is key for learning. Every malicious email that staff members report gives rise to post-incident analyses regarding the reasons it breached the system and how to update security (Interviews 8, 9) (E.d1). Post-incident alerts by the CSIRT and ACN—the ones published after incident reporting—may also trigger internal discussion (Interviews 8, 9). In the case of the law enforcement agency, it is routine procedure to check received alerts collectively, evaluate their significance, and discuss possible responses, updates, or changes (Interview 8). In the university administration, these procedures were present but were not institutionalized and rested on informal meetings (E.d1).

Further support for knowledge translation comes from post-incident evaluative judgments regarding the effectiveness and vulnerabilities shown during an incident response. Following the May DDoS attacks by KillNET, for instance, the former ACN director stated: "Due to the correct system configurations, we no longer had any significant primary sites down in recent campaigns" (Baldoni, 2022a) (E.d4). He also added a general evaluation of the effectiveness of establishing special rules for the PNCS, noting:

> there have been cases of incidents where the victim had a part of the digital infrastructure inside the PNCS and a part outside; this latter was completely encrypted by ransomware, while the infrastructure within the PNCS was properly protected and did not suffer any damage. (Baldoni, 2022a) (E.d4).

Similarly, after the incident that affected the Ministry of Ecological Transition, he outlined new objectives to address the vulnerability of the digital systems of the Italian public administration, including the implementation of "technical and organizational measures, as well as investments in hiring, training, and awareness" (Baldoni, 2022d) (E.d5). Finally, on several occasions, he stated how post-incident analysis confirmed known vulnerabilities and past objectives already present in ACN strategy 2022–2026 (ACN, 2022a) but yet to be implemented: establishing a public-private partnership to benefit from the support of private industry incident response teams (Baldoni, 2022a) (E.d5) and—following the analysis of a major ransomware attack on a national telecom provider—the need to create a national cloud (Baldoni, 2023) (E.d5).

5.5. Step E: Learning products

The final step pertains to the presence of learning products, namely changes, innovations, or confirmations in policies, regulations, programs, and objectives consistent with knowledge acquisition and its translation into lessons (Gerlak & Heikkila, 2011; Heikkila & Gerlak, 2013). In the case of incident notification, learning products are produced centrally by the ACN and CSIRT and locally by target administrations.

5.5.1. Learning products at the central level

The ACN and CSIRT elaborate lessons into actionable recommendations drafted into bulletins, alerts, and in-depth reports. Bulletins are published by the CSIRT whenever malicious campaigns, infections, exploits, and network vulnerabilities occur. They are normally structured in three parts: a general description of the type of attack and the types of subjects/technologies involved; the estimation of impacts, vulnerabilities, and technical characteristics of the incident; and suggested directions on mitigation actions (updates, disablements, etc.). Since 2020, CSIRT Italia has published 76 bulletins, 1621 alerts (similar to bulletins in structure but less detailed), and 20 reports (including in-depth analyses of international cyber threats, manuals, webinars, malware descriptions, and practical advice on the use of telematic devices).

These communications can be considered learning products per se; they represent post-incident outputs mandating changes in technology, tools, and procedures. However, they rarely mention the incident acquisition process and do not specify when incident reporting is the initial source of information. For this reason, for this section, we selected only some examples in which these references are clear (e.g., CSIRT Bulletin 09/08/2022), deducible from the text (e.g., CSIRT Alert 12/05/2022, CSIRT Bulletin 13/05/2022, and Bulletin 20/05/2022), or inferred from triangulation with other sources of information that explicitly mention incident notification (e.g., Baldoni, 2022b). These examples allowed us to trace the process between knowledge acquisition, translation, and learning products tightly enough to avoid false positives (Busetti & Righettini, 2023); however, they do not indicate the prevalence of incident reporting as a source of information, nor if and how frequently reporting does not produce learning products.

The first case regards a bulletin issued in August 2022 about continuing exploitation activities targeting vulnerabilities known as Log4Shell that affected the open-source software Log4j (Bulletin CSIRT 09/08/2022). The bulletin reported several lessons from the implementation of incident response activities, such as the need to verify compromised indicators, implement software updates, or conduct in-depth analyses of various systems to prevent new incidents or reduce the impact of those ongoing and undetected (E.e2). A similar example regards the May 2022 attack by the Russian collective KillNET against the Ministry of Defense, the Senate, and the Higher Institute of Health (Bulfon & Foschini, 2022). The ACN processed the data resulting from the attacks, created a collection of potential vulnerabilities (Alert CSIRT 12/05/2022), and subsequently issued two bulletins containing descriptions of the technical details of mitigation actions to be taken by possible targets (Bulletin CSIRT 13/05/2022; Bulletin 20/05/2022) (E.e1).

Post-incident learning may also suggest more radical changes that, however, are harder to implement. One example is the Note from the Presidency of the Council on February 6, 2023, following a ransomware

attack that compromised thousands of servers worldwide. In Italy, the attack affected the VMware ESXi servers of local Italian administrations as well as the network of the Italian telecommunication operator TIM. The note was drafted together with the ACN; it summarized the analysis of the incident and decided to implement two policy changes: the adoption of a government regulation to coordinate the prevention activities of regional governments with the ACN and the establishment of a periodic coordination table with all public and private entities providing critical services (Presidency of the Council, 2023) (E.e1). To date (March 2024), neither the regulation nor the coordination table has been implemented, suggesting this is a case of government inertia where learning products fail to produce policy change.

5.5.2. Learning products by target organizations

Bulletins, alerts, and publications are published on the ACN website and communicated through social media, ensuring wide diffusion of the incident and post-incident analysis to the benefit of potential targets. Information that emerged from our interviews shows that actors subject to mandatory reporting (those within the PNCS) receive direct dedicated information to the attention of the head of cybersecurity of their organization (Interview 8). This is evidence of a controlled communication channel that ensures PNCS's actors receive post-incident information in a timely manner (E.e7). By contrast, other administrations must check the data published by the ACN and CSIRT (Interviews 1, 2, 3), increasing the likelihood that those lessons will be missed. Effectiveness in communicating lessons is a needed intermediate step between learning products at the central level and their implementation by potential targets.

Regarding these latter, in our interviews with the university and the law enforcement agency, both organizations testified to analyzing threats daily using automatic systems, resolving vulnerabilities when found, and updating their infrastructure accordingly (E.e2). However, they also mentioned several cases of inertia and barriers to policy change, notwithstanding learned lessons. In the case of the university, inertia is derived from the lack of financial resources, limited political consensus, and the complexity of the administrative procedures needed to implement changes (Interviews 1, 2) (E.e4). While some technical details can be easily modified automatically by the responsible IT office or the SOC, major changes need approval by the organization's administrative and political boards, producing delays, vetoes, and decreased protection in a context where cybersecurity is not considered a priority.

The interviews with the law enforcement agency suggest two points for effectively implementing lessons. The first regards the need for agile internal procedures. The agency recalled a recent organizational change that eliminated most ex-ante authorizations; these latter produced significant delays in implementing prevention measures and made it impossible to deploy a timely response (Interviews 8, 9) (E.e7). Second, the agency lamented the impossibility of implementing technological updates because they did not have the necessary staff and could not outsource the job for security reasons (Interview 8) (E.e4). This latter problem reinforces the evidence of the capacity gap of target administrations.

6. Conclusion

This article investigates whether and how incident reporting can pursue the dual objective of fire alarm and trigger of a learning process. Table 2 summarizes the findings step-by-step; the remainder of this section highlights the main results of the evaluation.

The research provides only partial confirmation of the hypothesized program theory (see Appendix A). Incident reporting is undoubtedly effective as a fire alarm for short-term incident response. In particular, it can be essential for administrations with low levels of capacity and those subject to voluntary reporting. These organizations interpret incident reporting precisely as an alarm and a request for support for incidents that are not manageable in-house. This means that other incidents may be missed, notwithstanding their significance. Further, the performance of the alarm may be limited by the ability to detect and communicate incidents, which—in our research—is variable and subject to a possible reluctance to report incidents. This is a point of attention for policymakers.

Table 2
Main findings.

STEP A. DESIGN FEATURES
Congruent with the hypothesis.
• Advancements in the comprehensiveness of reporting
• Ambiguity in the inclusion of supply chain actors
• Rapid & in-depth reporting balance alarm and learning
• Reports provide only partial cybersecurity information
STEP B. DETECTION & REPORTING
Mostly incongruent with the hypothesis.
• Capacity gaps may hamper reporting
• Reluctance in reporting cyber-incidents
• Voluntary reporting serves as a request for support for incidents unmanageable in-house
• Need for constant training
• Need for reducing frictions in communication of incidents from non-IT staff
STEP C. INCIDENT RESPONSE
Mostly congruent with the hypothesis.
• Evidence of response capacity
• No evidence about triage
• Effectiveness of agreements for sharing data beyond reporting
STEP D. KNOWLEDGE TRANSLATION
Partly congruent with the hypothesis.
• Evidence of formalized and informal post-incident analyses, no evidence on frequency
STEP E. LEARNING PRODUCTS
Partly congruent with the hypothesis.
• Evidence of learning products
• Weak link with incident reporting
• Need for ensuring the communication of lessons to potential targets
• Several causes of inertia at both central and local levels
• Need for streamlining procedures for organizational change

Source: created by the authors.

Regarding the learning process, the evidence collected is limited due to the difficulty of tracing the link between implemented lessons and the information collected explicitly through reporting. We revealed the existence of dedicated communication channels which ensure that potential targets effectively receive lessons elaborated by cybersecurity actors at the central level; this is a design feature worth mainstreaming more widely in cybersecurity policy.

However, the analysis reveals several cases of inertia. While minor technical changes that can be directly implemented by an IT office or an SOC happen daily and almost automatically, when the changes envisaged after learning are more radical, go beyond the sole responsibility of the IT office, and need political and financial support, they easily remain unimplemented. The subsequent advice is to streamline the procedures for implementing changes within organizations to help ensure timely updates in response to a changing threat landscape.

The design of incident reporting has significantly strengthened from NIS1 to NIS2. Although there is still ambiguity about the role and duties connected to supply chain actors, the improved definition of significant incidents, the more precise timing, and the enlargement of the actors and incidents subject to mandatory reporting have greatly enlarged the coverage of this tool.

The combination of rapid reporting within hours and in-depth reporting within 30 days of the incident is a design detail that complements the two functions of fire alarm and policy learning. In particular, the in-depth report is the one conveying the most useful data for post-incident knowledge translation and learning products and may be worth introducing if not present in a country's legislation. Notice, however, that the relevance of incident reporting as a source of information is limited and needs to be put into perspective; cybersecurity actors gather much information from intelligence networks and

information channels other than incident reporting.

As mentioned, the capacity of target organizations is the most significant barrier to the effectiveness of incident reporting. Although they exhibit some variability, public organizations, in particular, have problems with staffing, technical capacity, and infrastructure. Our portrayal of the law enforcement agency—the presence of an SOC, an advanced training program, and proactive threat intelligence—is a reminder that adequate protection is challenging for ordinary administrations. In this respect, a transferrable lesson emerged from the analysis regards the importance of ensuring smooth internal communications so that all staff can report incidents to the IT office tasked with communicating to the CSIRT without red tape or other burdens.

Concerning incident response, we have presented several confirmations of the effectiveness of the CSIRT. A relevant qualification regards the adequacy of the information conveyed through reporting and the need to access further data that is not directly available through the reporting requirement. In this respect, drafting agreements for data sharing with organizations managing critical infrastructure can be a good practice to ensure that response teams have all the data necessary to deploy effective mitigation strategies.

A final comment regards the use of realist synthesis and—more generally—theory-based evaluation. This research shows that despite their apparent technological quality and automatic implementation, cybersecurity tools and procedures entail high complexity due to individual, organizational and political factors. A theory-based evaluation has great explanatory power: It indicates what would actually work, how, and for whom. Such explanatory ability is important for conceptual development and has a formative practical character; it helps provide policy-oriented advice to managers and policymakers. By highlighting unexpected causal pathways, the diverse response of implementers and possible adverse contextual conditions, the knowledge produced has practical relevance for designing, implementing, and reforming policy programs. Furthermore, this program theory can be used to assess other empirical cases of incident reporting and illuminate possible pitfalls and obstacles to their effective implementation.

CRediT authorship contribution statement

Simone Busetti: Writing – original draft, Supervision, Project administration, Methodology, Funding acquisition, Data curation, Conceptualization. **Francesco Maria Scanni:** Writing – original draft, Methodology, Investigation, Data curation.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgements

We acknowledge financial support by the Italian Ministry of University and Research (MUR), Project Title "Cybersecurity (as a) public policy – The institutionalization of platform and network security in the EU and Italy" – CUP C43C21000110001 - Grant Assignment Decree No. 266 adopted on 03/03/2022 by the Italian Ministry of University and Research (MUR).

Appendix A. Process tracing: Methodology and findings

Process tracing is a method for conducting in-depth case studies to assess causal processes and increase the reliability of within-case inferences. As applied in this article, the method entails the following phases:

1) *Elaboration of a causal process theory.* This is the program theory of incident reporting, as depicted in Fig. 2 and explained in section 4. It is elaborated through the analysis of official documents and identifies the actors, actions and causal sequence that goes from the program's design features to its expected results. Following Bayesian reasoning, the researcher also discusses the prior likelihood of the theory. As reported at the beginning of section 5, the part on 'fire alarm' is considered to have a high prior likelihood, whereas the one on policy learning has a low prior.
2) *Operationalization.* The theory is operationalized into empirical observables (pieces of evidence) derived by asking what evidence can be associated with each step in the theory. These observables are the theory's empirical fingerprints and tell the researcher what to look for in the fieldwork. They are reported in the first column in the tables below.
3) *Probative values.* Each piece of evidence is evaluated in terms of how likely we are to find it (certainty) and whether there are alternative explanations for finding it (uniqueness). Certainty refers to the likelihood of encountering evidence given the hypothesis's validity. Greater certainty implies that the evidence is expected if the hypothesis holds true, while lower certainty suggests that the absence of evidence doesn't significantly affect the hypothesis. Uniqueness, on the other hand, denotes the likelihood of discovering evidence assuming the hypothesis is false. A high level of uniqueness suggests that the evidence is distinctively associated with the hypothesis, not accounted for by other hypotheses. Conversely, low uniqueness implies numerous alternative explanations for the evidence. Discovering evidence with high uniqueness enhances the probability of the theory. The probative values are discussed in the second column of the tables below. Values of certainty and uniqueness are measured as low, moderate and high.
4) *Fieldwork.* This is the phase when one looks for the pieces of evidence identified in the previous phases. The data to be used can be both qualitative and quantitative and include primary and secondary sources. The third column in the tables below reports whether the pieces of evidence were found or not.
5) *Impact.* Considering the results of the fieldwork and the probative values, the researcher examines whether the evidence increases or lowers the likelihood of that part of the hypothesis. Disconfirming or confirming evidence does not necessarily impact the whole causal process; it only impacts one part. This is represented in the last column, highlighting the positive (+), negative (−) or null (=) impact of finding or not finding that piece of evidence.

STEP A. DESIGN FEATURES

The evidence is congruent with the hypothesis.

In the EU, there has been great progress in the design of reporting to make it more comprehensive in terms of the organizations covered, definition of incidents and quality of the information collected.

Evidence	Probative Value	Found/ Not found	Impact
E.a1 Presence of documentation on significant incident definition	A clear definition of what constitutes significant incidents is essential to guide the administrations responsible of incident reporting and to avoid an overload of reports. However, this evidence is not enough per se to ensure the effectiveness of reporting. Certainty: High Uniqueness: Low	Found	=
E.a2 Presence of significant attacks not included in the type of attacks subject to reporting	The presence of cyber-attacks that had major consequences but are not subject to reporting severly limits the effectiveness of the tool and can be sufficient proof of the. Certainty: Low Uniqueness: High	Not found	=
E.a3 Formal specification of organizations and types of attacks subject to reporting	It is essential to have documentation on the inclusion/exclusion of subjects and types of attacks to provide a reference for the administrations. However, it is not sufficient evidence to evaluate the effectiveness of reporting. Certainty: High Uniqueness: Low	Found	=
E.a4 Data (documents or statements) on inclusion/exclusion of relevant subjects/attacks	This is additional evidence with respect to the previous one, because it contains an evaluation of possible gaps following an analysis of the tool's effectiveness. If coming from central actors (CSIRT, ACN) it may hold a high level of uniqueness. Certainty: Low Uniqueness: High	Not found	=
E.a5 Account by key informants on the quality of the information contained in reporting	When asked, we expect both target administrations, CSIRT and the ACN to respond positively on the quality of the information communicated through reporting. If not, the effectiveness of reporting as a driver for learning would be severely impaired. Certainty: High Uniqueness: Low	Found	=
E.a6 Presence of documentation on the quality of the information covered by reporting	It is hard that this information would be formalized, but if available, it would provide sufficient evidence on the quality of reporting (either positively or negatively). Certainty: Low Uniqueness: High	Found	++
E.a7 Account by key informants on the need to exchange information with actors excluded from the reporting obligation (e.g. supply chain) or other parties (e.g. domestic or foreign intelligence services)	Reporting cannot provide all the information about cyber incidents. However, if alternative sources of information are prevalent, this would downplay the relevance of the tool. Certainty: Low Uniqueness: High	Not Found	=
E.a8 Existence of standardized procedures on reporting and its content (guidelines, standard contents, templates and so forth)	The presence of these documents may increase the consistency and completeness of the information reported. This standardisation is not necessary, but, when present, it can improve the quality of reporting. Certainty: Low Uniqueness: High	Partly found	+
E.a9 Data (documents or statements) on ease of use, contact, lack of adverse consequences, anonymity, etc. of the procedure	This type of evidence qualifies the effectiveness of the tool by assessing the ease and convenience of its usage. However, it is not a necessary proof of the correct functioning of the design. Certainty: Low Uniqueness: Moderate	Found	+

STEP B. DETECTION & REPORTING

The evidence is mostly not congruent with the hypothesis.

There is wide evidence regarding capacity gaps in administrations subject to reporting, hence the likelihood that detection and reporting will work properly is low. There is, however, heterogeneity across organizations with the presence of good performers.

Evidence	Probative Value	Found/ Not found	Impact
E.b1 Data (documents or statements) on capacity gaps impairing reporting	Data on the capacity of human resources in public and private organizations are available, although they often pertain to general IT skills and are not directly related to the functioning of incident reporting. However, evidence of poor/good IT and cybersecurity skills may be a good proxy. Certainty: Moderate Uniqueness: Moderate	Found	–
E.b2 Data (documents or statements) on insufficient technical equipments	To ensure a proper detection and reporting procedure, administrations need to have adequate technical equipments. However, this does not provide enough insight into the actual working of incident reporting. Certainty: Moderate Uniqueness: Low	Found	=
E.b3 Data (documents or statements) on ability to acquire information on significant events from within the organization or its supply chain	It is essential to acquire information on relevant attacks from both internal staff and supply chain actors. While information from the supply chain is relevant only to some administrations, systems for internal communication of incidents are fundamental for the effectiveness of reporting.	Partly found	=

(*continued on next page*)

(*continued*)

STEP B. DETECTION & REPORTING

The evidence is mostly not congruent with the hypothesis.

There is wide evidence regarding capacity gaps in administrations subject to reporting, hence the likelihood that detection and reporting will work properly is low. There is, however, heterogeneity across organizations with the presence of good performers.

Evidence	Probative Value	Found/ Not found	Impact
	Certainty: High Uniqueness: Low		
E.b4 Data (documents or statements) on monitoring, receipt and use of CSIRT alerts	Such activities can support prevention strategy and are sufficient proof of the use of CSIRT alerts. However, especially when formalized, they testify a level of advanced capacity which is not to be expected in most organizations. Certainty: Low Uniqueness: High	Not found	=
E.b5 Data (documents or statements) on the presence of monitoring systems of cyber threats and the update of technical equipments (including systems of quality certification)	Monitoring procedures are essential for the proper function of detection. However, this evidence alone is not sufficient to assess the correct execution of these procedures, nor does it provide any information about the effectiveness of reporting. Certainty: High Uniqueness: Low	Found	=
E.b6 Presence of training, upgrading and/or upskilling/upgrading for personnel and systems	Continual updating personnel and systems is an essential element in cybersecurity, necessary for the proper functioning of detection. Notwithstanding, the quality of reporting may also depend on other factors such as responsiveness, willingness, and incentives. Certainty: High Uniqueness: Low	Partly Found	=
E.b7 Presence of formalized documents of the administration's cybersecurity policies (with roles, actions, planning)	Although they are not easily accessible, formal documents assigning roles and responsibilities for cybersecurity are necessarily present in public administrations. However, this does not provide much insight into the quality of detection and reporting activities. More advanced documents with activities, planning and formalized procedures are present only in organizations with advanced capacity. Certainty: High Uniqueness: Low	Partly found	=
E.b8 Data (documents or statements) on unwillingness to report incidents	Such documents or statements are rare to find and disclose. If they are, they are sufficient proof that there are barriers to reporting. Certainty: Low Uniqueness: High	Found	–
E.b9 Data (documents or statements) on the number of events detected (by CSIRT or others) but not reported	If existent, these data will hardly be disclosed. If found, they are sufficient proof of a gap in the reporting system. Certainty: Low Uniqueness: High	Not found	=
E.b10 Data (documents or statements) on the number of events detectable by reporting administrations but emerged through other sources	If existent, these data will hardly be disclosed. If found, they may be sufficient proof of a gap in capacity by reporting administrations. Notice that not all incidents or threats need to be revealed through reporting. However, precise figures are probably impossible to find. Certainty: Low Sufficiency: High	Not found	=

STEP C. INCIDENT RESPONSE

The evidence is mostly congruent with the hypothesis.

There are several proofs of the capacity and effectiveness of the CSIRT. However, only major incidents are public and cases of omissions may have escaped the research.

Evidence	Probative Value	Found/ Not found	Impact
E.c1 Presence of data/statements on CSIRT incident response interventions.	Such documents may be classified as confidential. When present, they may not tell if the CSIRT's activity is derived from the incident reporting process or other sources, such as independent monitoring or information from supranational or international actors. Certainty: Moderate Uniqueness: Moderate	Partly found	+
E.c2 Presence of standardized procedures of communication with the target administration	For proper incident response, it is necessary for the CSIRT and the administration to have a system of communication that ensure speed and quality of intervention. However, this evidence alone is not sufficient to certify the effectiveness of CSIRT response. Certainty: High Uniqueness: Low	Found	=
E.c3 Data (documents or statements) regarding the effectiveness/ineffectiveness in incident management by CSIRT	These statements may be hard to find and be difficult to evaluate. If coming as a self-evaluation by CSIRT there could be some overstatement; if from other actors they can be reliable. Certainty: Low Uniqueness: High	Found	+
E.c4 Data (documents or statements) regarding CSIRT under-staff	These data may be a proxy of the level of capacity of the CSIRT (for instance, if the team can respond to the requests or is overloaded). However, if such statements come from CSIRT or ACN, one should be wary that this deficit can be overemphasised for several reasons (for justifying inefficiencies or, if a public statement, to exert pressure on policymakers to obtain more resources). Certainty: Moderate Uniqueness: Moderate	Found	=

(*continued on next page*)

(*continued*)

STEP C. INCIDENT RESPONSE

The evidence is mostly congruent with the hypothesis.

There are several proofs of the capacity and effectiveness of the CSIRT. However, only major incidents are public and cases of omissions may have escaped the research.

Evidence	Probative Value	Found/ Not found	Impact
E.c5 Data (documents or statements) regarding technology deficits	Documents are impossible to find (they could signal possible targets and expose the organization to targeted attacks). Statements might be collected in confidential interviews and would constitute sufficient evidence of technology gaps (especially if coming directly from CSIRT). Certainty: Low Uniqueness: High	Not found	=
E.c6 Data (documents or statements) on the lack of legal jurisdiction to act	Such data could help clarify the legal limits imposed on the CSIRT's actions. They may testify gaps in the implementation of the response systems although they can hardly be disclosed. Certainty: Low Uniqueness: Moderate	Not found	=
E.c7 Data (documents or statements) on the lack of response by CSIRT	Some triage is always necessary; the point is whether the CSIRT is unable to respond to relevant incidents. Reliable data are hardly disclosed; if found they can provide sufficient evidence on gaps in the response procedures. Certainty: Low Uniqueness: High	Not found	=
E.c8 Existence of standardized procedures for responding to some classes of incidents	The presence of standard procedures to address cyber crises is a key element in advancing the capacity to act promptly and effectively. At the same time, the presence of formalized procedure is only one element of response capacity. Regarding certainty, the publication of these documents could facilitate attackers in updating their attack strategies. In this respect, even if they are present, they are unlikely to be disclosed. Certainty: Low Uniqueness: Moderate	Not found	=
E.c9 Performance of exercises, simulations and feedback on results	Simulation exercises and other active training are essential for updating the incident response activity in light of the evolution of attacks. This evidence certifies an effort to improve the functioning of vulnerability management by the CSIRT. It is a moderately advanced activity, not necessarily to be found for all organizations. Certainty: Moderate Uniqueness: High	Found	=

STEP D. KNOWLEDGE TRANSLATION

The evidence is partly congruent with the hypothesis.

Although knowledge translation may not be present in records, we found evidence of formalized and informal post-incident analyses, together with public evaluative statements regarding lessons learned. The link between knowledge translation and the specific information gathered through reporting is not always clear.

Evidence	Probative Value	Found/ Not found	Impact
E.d1 Data (documents or statements) related to discussion, processing, analysis of information gained from incident reporting/response experience	Evidence of analysis activities by central or peripheral administrations is crucial and constitutes sufficient proof of knowledge translation when found. The link with incident reporting may be blurred. Certainty: High Uniqueness: High	Partly found	+
E.d2 Presence of a register monitoring past incidents and/or formalized procedures for post-mortem analyses	The presence of incident analysis procedures is sufficient evidence to evaluate the proper functioning of the procedure. However, these activities may not necessarily be formalized in records or other internal documents within the administrations. These formal documents and procedure testify an advanced commitment to knowledge translation. Certainty: Low Uniqueness: High	Found	+
E.d3 Post-incident data (documents or statements) related to inefficiencies of prevention, attack management, regulations	These data can be hard to find and to be confirmed by stakeholders. If found, they provide sufficient evidence of post-incident analysis. Certainty: Low Uniqueness: High	Not found	=
E.d4 Post-incident data (documents or statements) regarding the effectiveness of prevention and response systems	Generally, it can be expected that administrations tend to highlight the effectiveness of implemented procedures over existing gaps. If present, these data do not constitute sufficient evidence. Certainty: Moderate Uniqueness: Low	Found	=
E.d5 Presence of post-incident data (documents or statements) regarding goals, programs, or tools suggested by the reporting/ response experience	Administrations might also be reluctant to reveal the need for changes if they are associated with the failure of previously implemented tools. They might justify new objectives with generic reasons (not connected to reporting/attack experience). If explicitly linked to the lessons learned, these data can serve as sufficient evidence of post-incident analysis and knowledge translation. Certainty: Low Uniqueness: High	Found	+

STEP E. LEARNING PRODUCTS

The evidence is only partly congruent with the hypothesis.

We found several instances of lessons applied into learning products, but the link with the information specifically gathered through incident reporting is weak. There are also several cases of post-incident inertia and evidence of heterogeneity across organizations regarding their ability to implement lessons.

(*continued on next page*)

(*continued*)

STEP E. LEARNING PRODUCTS

The evidence is only partly congruent with the hypothesis.

We found several instances of lessons applied into learning products, but the link with the information specifically gathered through incident reporting is weak. There are also several cases of post-incident inertia and evidence of heterogeneity across organizations regarding their ability to implement lessons.

Evidence	Probative Value	Found/ Not found	Impact
Evidence	Probative Value	Found/ Not found	Impact
E.e1 Innovations, changes or confirmations in activities, tools, programs, goals congruent with lessons learned	The likelihood of finding learning products that are congruent with the lessons learned but independent from them is quite low. However, congruence is not the only evidence of the learning process and do not ensure the link with the information gathered through reporting. Certainty: High Uniqueness: Moderate	Found	+
E.e2 Data (documents or statements) regarding congruence of innovations/changes/confirmations with lessons learned through reporting	This is additional evidence with respect to the previous one; there can be enough confidence on the truthfulness of such accounts especially when stakeholders admit innovations were needed to change inefficient programs. Certainty: High Uniqueness: High	Partly found	+
E.e3 Data (documents or statements) that some lessons were not followed because context had changed and/or they were no longer relevant	When lessons were not implemented into changes, outdated learning may be evidence of a learning product. However, policymakers may tend to exaggerate the effect of contextual change to cover inertia. Certainty: High Uniqueness: Low	Not found	=
E.e4 Data (documents or statements) on the fact that lessons learned were not followed because of inertia or major obstacles impeding policy change	Policymakers may be especially resistant to admit inertia; if found, the evidence is sufficient proof. Certainty: Low Uniqueness: High	Found	−
E.e5 Data (documents or statements) that innovations/changes implemented do not result from learning	Admitting false positives may be rare for key actors and policymakers; if found, it represents sufficient proof. Certainty: Low Uniqueness: High	Not found	=
E.e6 Data (documents or statements) on innovations/changes contrary to lessons learned	Policymakers would be unlikely to admit to acting in a manner contrary to the lessons learned. If found, this constitutes sufficient evidence of the gaps in the learning process. Certainty: Low Uniqueness: High	Not found	=
E.e7 Data (documents or statements) about specific procedures for the diffusion and application of lessons learned	Although they do not ensure implementation, the presence of specific procedure to communicate and implement lessons can streamline policy change. We do not expect these procedures to be necessarily in place. Certainty: Low Uniqueness: Moderate	Partly found	+

Appendix B. Interview protocol

Table 3
List of interviews.

Interview code	Interviewee	Affiliation	Interview date
Interview 1	ICT Office Manager	University	26/01/2023
Interview 2	ICT Office Member	University	26/01/2023
Interview 3	IT External Consultant	University	26/01/2023
Interview 4	Executive	ACN - National Cybersecurity Agency	03/05/2023
Interview 5	Member	ACN - National Cybersecurity Agency	03/05/2023
Interview 6	Member	ACN - National Cybersecurity Agency	05/05/2023
Interview 7	General	Law enforcement agency	20/06/2023
Interview 8	Head of IT direction	Law enforcement agency	10/07/2023
Interview 9	SOC Manager	Law enforcement agency	10/07/2023
Interview 10	Chief computer service	Law enforcement agency	10/07/2023
Interview 11	Security Manager	IT Company	15/12/2023

INTERVIEW FORMAT
Personal data

- Interview No.
- Date
- Interviewee
- Administration

Organization

- What are the competencies and functions of [interviewee's organization] in cybersecurity?
- What types of cases do you generally work on? What are the subjects/incidents within your jurisdiction? Which incidents are the most frequent? Are there any critical/problematic cases/subjects?
- How do you start working on a specific case? (CSIRT notification? Self-identification? Reporting?)
- How is the function organized? Staff, units? Are there any critical aspects, strengths, or room for improvement? (personnel, technical resources, incident monitoring procedures, personnel training, certification of systems and procedures)
- Which organizations do you have contacts (collaboration, communication, service) for cybersecurity? What are the activities/subjects?
- What interactions do you have with ACN and CSIRT? Are there any critical aspects/areas for improvement?

Incident response

- Talking about the [interviewee's organization] as the target of an attack: what are the typical incidents?
- If your organization was to experience an attack, what would happen?
- Do you report the incident to CSIRT-ACN? What is their response?
- What information is communicated? Are there any that you do not communicate or cannot communicate but could be relevant for containment?
- Is notification a necessary/effective tool? What are the objectives? (four hypotheses: formal procedure, accountability, response, learning).
- What are the critical issues, strengths, and potential developments of the tool? (including those related to CSIRT's preparedness or capabilities) (ease of notification, effectiveness of response, ease of collaboration/communication)
- Unreported incidents? Why? (e.g., not necessary because they can be easily resolved internally)
- Are there organizations in your jurisdictions that tend not to report incidents? Why?
- Are there potentially harmful incidents that are not subject to the reporting obligation?

Post-incident learning

- Once the response to an attack is completed, is there a subsequent phase of incident analysis?
- Is the information acquired during incident response used/processed in any way? (log, data processing statistics, working groups?) What is the workflow?
- Can you recall any results of this analysis? (e.g. elements of effectiveness/ineffectiveness?
- Were there any changes resulting from the incident analysis? (objectives, procedures, strategies, programs, infrastructure)
- Difficulties in post-incident change? Are there cases of inertia, lessons learned, or known cases of ineffectiveness that have not led to changes? Why?

B.1. Conclusion

- Are there other people we could contact to discuss incident response and analysis?

References

Atkins, S., & Lawson, C. (2021). An improvised patchwork: Success and failure in cybersecurity policy for critical infrastructure. *Public Administration Review, 81*(5), 847–861. https://doi.org/10.1111/puar.13322

Azmi, R., Tibben, W., & Win, K. T. (2018). Review of cybersecurity frameworks: Context and shared concepts. *Journal of Cyber Policy, 3*(2), 258–283. https://doi.org/10.1080/23738871.2018.1520271

Badsha, S., Vakilinia, I., & Sengupta, S. (2019). Privacy preserving cyber threat information sharing and learning for cyber defense. In *2019 IEEE 9th Annual Computing and Communication Workshop and Conference (CCWC)* (pp. 0708–0714). https://doi.org/10.1109/CCWC.2019.8666477

Battisti, D. (2020). The digital transformation of Italy's public sector: Government cannot be left behind! *JeDEM - eJournal of eDemocracy and Open Government, 12*(1), 25–39. https://doi.org/10.29379/jedem.v12i1.591

Beach, D., & Pedersen, R. B. (2019). *Process-tracing methods: Foundations and guidelines*. University of Michigan Press.

Brady, H. E., & Collier, D. (2010). *Rethinking social inquiry: Diverse tools, shared standards*. Rowman & Littlefield Publishers.

Busenberg, G. J. (2001). Learning in organizations and public policy. *Journal of Public Policy, 21*(2), 173–189.

Busetti, S., & Righettini, M. S. (2023). Policy learning from crises: Lessons learned from the Italian food stamp Programme. *Policy & Politics, 51*(1), 91–112. https://doi.org/10.1332/030557321X16678318518550

Cadzow, S., Sanchez, I., & Baldini, G. (2018). *An analysis on the development and application of cybersecurity standards*. Joint Res. Centre, Petten, The Netherlands, Tech. Rep. JRC110858.

Christou, G. (2016). *Cybersecurity in the European Union: Resilience and adaptability in governance policy*. Springer.

Conti, M., Dargahi, T., & Dehghantanha, A. (2018). Cyber threat intelligence: Challenges and opportunities. In A. Dehghantanha, M. Conti, & T. Dargahi (Eds.), *Cyber threat intelligence* (pp. 1–6). Cham: Springer International Publishing. https://doi.org/10.1007/978-3-319-73951-9_1.

Ciardi, N. (2023): "Convivere con il rischio imparando a gestirlo". Retrieved from https://www.cybersecurity360.it/cybersecurity-nazionale/nunzia-ciardi-acn-convivere-con-il-rischio-cyber-imparando-a-gestirlo/ Accessed March 13, 2024.

Correia, S. G. (2022). Making the most of cybercrime and fraud crime report data: A case study of UK action fraud. *International Journal of Population Data Science, 7*(1). https://doi.org/10.23889/ijpds.v7i1.1721

Correia-Hopkins, S. (2024). A framework for measuring the quality of police recorded cybercrime data, illustrated through a UK/USA comparison. *The Crime Data Handbook, 260*.

Cram, W. A., & Mouajou-Kenfack, R. (2022). Show-and-tell or Hide-and-seek? Examining organizational cybersecurity incident notifications. *Organizational Cybersecurity Journal: Practice, Process and People, 3*(1), 1–17. https://doi.org/10.1108/OCJ-06-2022-0011

Crick, T., Davenport, J. H., Irons, A., & Prickett, T. (2019, October). A UK case study on cybersecurity education and accreditation. In *In 2019 IEEE Frontiers in education conference (FIE)* (pp. 1–9). IEEE.

Dupont, B. (2019). Enhancing the effectiveness of cybercrime prevention through policy monitoring. *Journal of Crime and Justice, 42*(5), 500–515. https://doi.org/10.1080/0735648X.2019.1691855

Fuster, G. G., & Jasmontaite, L. (2020). Cybersecurity regulation in the European Union: The digital, the critical and fundamental rights. *The Ethics of Cybersecurity*, 97–115.

Gerlak, A. K., & Heikkila, T. (2011). Building a theory of learning in Collaboratives: Evidence from the Everglades restoration program. *Journal of Public Administration Research and Theory, 21*(4), 619–644. https://doi.org/10.1093/jopart/muq089

Gerring, J. (2007). *Case study research. Principles and practices*. Cambridge: Cambridge University Press.

Golden, J. (2018). The darkening storm of cyberterrorism: International policy adaptation for automotive cybersecurity regulations. *Jurimetrics, 59*, 267.

Heikkila, T., & Gerlak, A. K. (2013). Building a conceptual approach to collective learning: Lessons for public policy scholars. *Policy Studies Journal, 41*(3), 484–512. https://doi.org/10.1111/psj.12026

Johnson, W., & Chris. (2015). Architectures for cyber-Security incident reporting in safety-critical systems. In A. Masys (Ed.), *Disaster Management: Enabling Resilience*

(pp. 127–141). Cham: Springer International Publishing. Lecture Notes in Social Networks. https://doi.org/10.1007/978-3-319-08819-8_7

Kamara, I., Ronald Leenes, C., & Stuurman, and Jasper van den Boom.. (2020). *The cybersecurity certification landscape in the Netherlands after the union cybersecurity act*. National Cybersecurity Centre.

Khurana, H., Basney, J., Bakht, M., Freemon, M., Welch, V., & Butler, R. (2009). Palantir: A framework for collaborative incident response and investigation. In *Proceedings of the 8th Symposium on Identity and Trust on the Internet, 38–51. IDtrust '09*. New York, NY, USA: Association for Computing Machinery. https://doi.org/10.1145/1527017.1527023.

Khurshid, A., Alsaaidi, R., Aslam, M., & Raza, S. (2022). EU cybersecurity act and IoT certification: Landscape, perspective and a proposed template scheme. *IEEE Access, 10*, 129932–129948. https://doi.org/10.1109/ACCESS.2022.3225973

Lewallen, J. (2021). Emerging technologies and problem definition uncertainty: The case of cybersecurity. *Regulation & Governance, 15*(4), 1035–1052. https://doi.org/10.1111/rego.12341

Luiijf, E., & Klaver, M. (2015). On the sharing of cyber Security information. In *In critical infrastructure protection IX, edited by Mason Rice and Sujeet Shenoi, 29–46. IFIP Advances in Information and Communication Technology*. Cham: Springer International Publishing. https://doi.org/10.1007/978-3-319-26567-4_3.

Markopoulou, D., Papakonstantinou, V., & de Hert, P. (2019). The new EU cybersecurity framework: The NIS directive, ENISA's role and the general data protection regulation. *Computer Law and Security Review, 35*(6), Article 105336. https://doi.org/10.1016/j.clsr.2019.06.007

Matassa, M. (2022). Una strategia nazionale a difesa del cyberspazio. *P.A. Persona e Amministrazione, 11*(2), 625–654.

Michail, A. (2020). *Tackling the challenges of information Security incident reporting: A decentralized approach*. PhD Thesis,. University of East London https://repository.uel.ac.uk/item/88q0y.

Mijwil, M., Unogwu, O. J., Filali, Y., Bala, I., & Al-Shahwani, H. (2023). Exploring the top five evolving threats in cybersecurity: An in-depth overview. *Mesopotamian Journal of CyberSecurity, 2023*(March), 57–63. https://doi.org/10.58496/MJCS/2023/010

Morgan, A., Dowling, C., Brown, R., Mann, M., Voce, I., & Smith, M. (2016). Evaluation of the Australian Cybercrime Online Reporting Network. https://eprints.qut.edu.au/121532/.

Mughal, A. A. (2018). The art of cybersecurity: Defense in depth strategy for robust protection. *International Journal of Intelligent Automation and Computing, 1*(1), 1–20.

Newmeyer, K. P. (2015). Elements of national cybersecurity strategy for developing nations. *National Cybersecurity Institute Journal, 1*(3), 9–19.

Norris, D. F., & Mateczun, L. K. (2022). Cyberattacks on local governments 2020: Findings from a key informant survey. *Journal of Cyber Policy, 7*(3), 294–317. https://doi.org/10.1080/23738871.2023.2178319

Onwubiko, C. (2015). Cyber security operations centre: Security monitoring for protecting business and supporting cyber defense strategy. In *2015 International conference on cyber situational awareness, data Analytics and assessment (Cybersa)* (pp. 1–10). IEEE. https://ieeexplore.ieee.org/abstract/document/7166125/.

Pala, A., & Zhuang, J. (2019). Information sharing in cybersecurity: A review. *Decision Analysis, 16*(3), 172–196. https://doi.org/10.1287/deca.2018.0387

Pawson, R. (2002). Evidence-based policy: The promise of `realist synthesis. *Evaluation, 8*(3), 340–358. https://doi.org/10.1177/135638902401462448

Pawson, R., Greenhalgh, T., Harvey, G., & Walshe, K. (2004). Realist synthesis: An introduction. In *An Introduction*.

Rossa, S. (2023). *Cybersicurezza e Pubblica Amministrazione. 24*. Editoriale Scientifica https://iris.uniupo.it/handle/11579/154962.

Sagan, S. D. (1993). *The limits of safety | Princeton University press*. Princeton: Princeton University Press.

Sangari, S. (2022). *Debiasing cyber incidents – Correcting for reporting delays and under-reporting*. August: Doctor of Data Science and Analytics Dissertations. https://digitalcommons.kennesaw.edu/dataphd_etd/13.

Santos, O. (2018). *Developing cybersecurity programs and policies*. Pearson IT Certification.

Schmitz-Berndt, S. (2023). Defining the reporting threshold for a cybersecurity incident under the NIS directive and the NIS 2 directive. *Journal of Cybersecurity, 9*(1), tyad009. https://doi.org/10.1093/cybsec/tyad009

Schmitz-Berndt, S., & Chiara, P. G. (2022). One step ahead: Mapping the Italian and German cybersecurity Laws against the proposal for a NIS2 directive. *International Cybersecurity Law Review, 3*(2), 289–311. https://doi.org/10.1365/s43439-022-00058-7

Schünemann, W. J., & Baumann, M.-O. (Eds.). (2017). *Privacy, data protection and cybersecurity in Europe*. Cham: Springer International Publishing. https://doi.org/10.1007/978-3-319-53634-7.

Sule, M.-J., Zennaro, M., & Thomas, G. (2021). Cybersecurity through the Lens of digital identity and data protection: Issues and trends. *Technology in Society, 67*(November), Article 101734. https://doi.org/10.1016/j.techsoc.2021.101734

Sveen, O., Finn, Sarriegi, J. M., Rich, E., & Gonzalez, J. J. (2007). "Toward viable information security reporting systems." Edited by Steven Furnell and Nathan Clarke. *Information Management & Computer Security, 15*(5), 408–419. https://doi.org/10.1108/09685220710831143

Thaler, R. H., & Sunstein, C. R. (2021). *Nudge: The Final Edition*. Yale University Press.

Tsvilii, O. (2021). *Cyber Security regulation: Cyber Security certification of operational technologies*. Rochester, NY: SSRN Scholarly Paper. https://papers.ssrn.com/abstract=3796990.

West-Brown, M. J., Stikvoort, D., Kossakowski, K.-P., Killcrece, G., Ruefle, R., & Zajicek, M. (1998). *Handbook for computer Security incident response teams (CSIRTs)*. Software Engineering Institute: Carnegie Mellon University. https://apps.dtic.mil/sti/citations/tr/ADA413778.

Zibak, A., & Simpson, A. (2019). Cyber threat information sharing: Perceived benefits and barriers. In *Proceedings of the 14th International Conference on Availability, Reliability and Security, 1–9. ARES '19*. New York, NY, USA: Association for Computing Machinery. https://doi.org/10.1145/3339252.3340528.

Case study material

ACN. (2022a). *Strategia Nazionale di Cybersicurezza 2022–2026*. Retrieved from https://www.acn.gov.it/ACN_Strategia.pdf Accessed March 13, 2024.

ACN. (2022b). *Cyber Europe 2022*. Retrieved from https://www.acn.gov.it/notizie/contenuti/cyber-europe-2022 Accessed March 13, Accessed March 13, 2024.

ACN. (2022c). *Relazione Annuale al Parlamento*. Retrieved from https://www.acn.gov.it/documents/ACN_Rel_Parlamento_2021.pdf Accessed March 13, 2024.

ACN. (2022d). *ACN-Banca d'Italia, accordo firmato*. Retrieved from https://www.acn.gov.it/notizie/contenuti/acn-banca-italia-accordo-firmato Accessed March 13, 2024.

ACN. (2023). *ACN e Camera dei Deputati, unite contro le minacce cyber*. Retrieved from https://www.acn.gov.it/notizie/contenuti/acn-e-camera-dei-deputati-unite-contro-le-minacce-cyber Accessed March 13, 2024.

ACN website. (n.d.) Operazioni CSIRT Italia. Retrieved from https://www.acn.gov.it/agenzia/attivita/operazioni Accessed March 13, 2024.

Baldoni, R. (2022a). *Baldoni, Agenzia Cyber: "Draghi ci ha chiesto rigore e rapidità per rendere l'Italia sicura"*. Retrieved from https://www.repubblica.it/tecnologia/2022/07/06/news/intervista_baldoni_agenzia_cybersicurezza_nazionale-356634977/ Accessed March 13, 2024.

Baldoni, R. (2022b). *MiTe, torna online il sito. Baldoni: "Evitati danni maggiori"*. Retrieved from https://www.cybersecitalia.it/mite-torna-online-il-sito-baldoni-evitati-danni-maggiori/18100 Accessed March 13, 2024.

Baldoni, R. (2022c). *Baldoni, direttore Agenzia per la cybersecurity: "L'Italia è a caccia di cervelli"*. Retrieved from https://www.repubblica.it/cronaca/2022/02/21/news/baldoni_direttore_agenzia_per_la_cybersecurity_litalia_e_a_caccia_di_cervelli_assumiamo_72_persone_con_stipendi_a_livel-338708064/ Accessed March 13, 2024.

Baldoni, R. (2022d). *Il mistero del ministero scomparso (dal Web): "Tecnici al lavoro per il ripristino"*. Retrieved from https://www.repubblica.it/tecnologia/2022/04/08/news/il_mistero_del_ministero_scomparso_dal_web_tecnici_al_lavoro_per_il_ripristino-344676526/ Accessed March 13, 2024.

Baldoni, R. (2022e). *Cybersecurity, così saliremo sul treno europeo. Parla Baldoni*. Retrieved from https://formiche.net/2022/08/cybersecurity-ue-baldoni/ Accessed March 13, 2024.

Baldoni, R. (2023). *Il Cantiere della cybersicurezza: sviluppo tecnologico e autonomia strategica nazionale*. Retrieved from https://www.acn.gov.it/documents/BaldoniDiscorsoLuiss20230222.pdf Accessed March 13, 2024.

Brunetta, R. (2022). *Question time Camera dei Deputati*. Retrieved from https://www.corrierecomunicazioni.it/cyber-security/cybercrime-lagenzia-per-la-cybersicurezza–respinge-lattacco-di-killnet/ Accessed March 13, 2024.

Bulfon, F., & Foschini, G. (2022). *Attacco hacker a siti italiani, anche Senato e Difesa. Rivendicato dal collettivo russo Killnet*. Retrieved from https://www.repubblica.it/politica/2022/05/11/news/attacco_hacker_russi_a_siti_italiani_senato_difesa Accessed March 13, 2024.

CERT-AGID. (2020). *Monitoraggio sul corretto utilizzo del protocollo HTTPS e dei livelli di aggiornamento delle versioni dei CMS nei portali Istituzionali della PA*. Retrieved from https://cert-agid.gov.it/news/monitoraggio-sul-corretto-utilizzo-del-protocollo-https-e-dei-livelli-di-aggiornamento-delle-versioni-dei-cms-nei-portali-istituzionali-della-pa/ Accessed March 13, 2024.

Colao, V. (2021). *Sempre più hacker sul web, e più fame di server protetti. Così i gestori massimizzano i portafogli*. Retrieved from https://www.lastampa.it/tuttosoldi/2021/06/14/news/sempre- piu-hacker-sul-web-e-piu-fame-di-server-protetti-cosi-i-gestori-massimizzano-i-portafogli- 1.40379837/ Accessed March 13, 2024.

CREST. (2013). *Cyber Security Incident Response Guide*. Retrieved from https://www.crest-approved.org/wp-content/uploads/2022/04/CSIR-Procurement-Guide-1.pdf Accessed March 3, 2024.

CSIRT. (2023). *RFC2350 Document*. Retrieved from https://www.csirt.gov.it/rfc2350.txt Accessed March 13, 2024.

CSIRT website (n.d.). FAQ. Retrieved from https://www.csirt.gov.it/faq Accessed March 13, 2024.

Deutscher Bundestag. (2021). *Beschlussempfehlung und Bericht des Ausschusses für Inneres und Heimat (4. Ausschuss)*. Retrieved from https://dserver.bundestag.de/btd/19/288/1928844.pdf Accessed March 13, 2024.

ENISA. (2006). *A step-by-step approach on how to set up a csirt*. Retrieved from https://www.enisa.europa.eu/publications/csirt-setting-up-guide Accessed March 3, 2024.

ENISA (2013). Annual Incident Reports 2012. Retrieved from https://www.enisa.europa.eu/publications/annual-incident-reports-2012, Accessed March 13, 2024.

ENISA. (2014). *Technical guideline on incident reporting*. Retrieved from https://www.enisa.europa.eu/publications/technical-guideline-on-incident-reporting Accessed March 3, 2024.

ENISA. (2015). *Guideline on threats and assets*. Retrieved from https://resilience.enisa.europa.eu/article-13/guideline_on_threats_and_assets/Guideline_on_Threats_and_Assets_v_1_1.pdf Accessed March 13, 2024.

ENISA. (2022a). *Consolidated annual activity report*. Retrived from https://www.enisa.europa.eu/publications/corporate-documents/enisa-annual-activity-report-2022.pdf/ Accessed March 12, 2024.

ENISA. (2022b). *Annual report telecom security incidents*. Retrieved from https://www.enisa.europa.eu/publications/telecom-security-incidents-2021 Accessed March 13, 2024.

ENISA. (2023). *Good Practices for Supply Chain Cybersecurity*. Retrieved from https://www.enisa.europa.eu/publications/good-practices-for-supply-chain-cybersecurity Accessed March 13, 2024.

ENISA (website n.d.). Incident reporting supports the understanding and analysis of the EU cybersecurity ecosystem. Retrieved from https://www.enisa.europa.eu/topics/incident-reporting Accessed March 13, 2024.

EU Commission. (2020). *Impact assessment Proposal for directive on measures for high common level of cybersecurity across the Union*. Retrieved from https://digital-strategy.ec.europa.eu/en/library/impact-assessment-proposal-directive-measures-high-common-level-cybersecurity-across-union Accessed March 13, 2024.

Fioroni, M. (2022). *L'account Twitter del ministero della Transizione ecologica è stato hackerato*. Retrieved from https://www.repubblica.it/tecnologia/2022/09/15/news/hacker_account_twitter_ministero_transizio ne_ecologica_mite_ethereum-365749135/ Accessed March 13, 2024.

Forrester Analytics. (2022). *The 2021 State of Enterprise Breaches*. Retrieved from https://www.forrester.com/report/the-2021-state-of-enterprise-breaches/RES177333 Accessed March 13, 2024.

Frattasi, B. (2023). *Frattasi: La Cybersicurezza è trasversale. Strategico "fare sistema"*. Retrieved from https://www.acn.gov.it/notizie/contenuti/frattasi-la-cybersicurezza-e-trasversale-strategico-fare-sistema Accessed March 13, 2024.

HM Government UK. (2022). *Government Cyber Security Strategy UK*. Retrieved from https://www.gov.uk/government/publications/government-cyber-security-strategy-2022-to-2030 Accessed March 3, 2024.

ISPI. (2022). *Roberto Baldoni - Cooperazione mediterranea per la cybersicurezza - MED22*. Retrieved from https://www.acn.gov.it/notizie/contenuti/med2022-il-direttore-generale-al-cyber-forum Accessed March 13, 2024.

Keeper Security. (2023). *Cybersecurity disasters survey incident reporting & disclosure*. Retrieved from https://www.keepersecurity.com/it_IT/ Accessed March 13, 2024.

NIST. (2004). *Computer security incident handling guide*. Retrieved from https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-61.pdf Accessed March 3, 2024.

NIST. (2012). *Recommendations of the National Institute of Standards and Technology*. Retrieved from https://resilience.enisa.europa.eu/article13/guideline_on_threats_and_assets/Guideline_on_Threats_and_Assets_v_1_1.pdf Accessed March 13, 2024.

NIST. (2018). *Framework for improving critical infrastructure cybersecurity*. Retrieved from https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf Accessed August 1, 2023.

Presidency of the Council. (2023). *Attacco informatico, riunione a Palazzo Chigi*. Retrieved from https://www.governo.it/it/articolo/attacco-informatico-riunione-palazzo-chigi/21715 Accessed March 13, 2024.

Rai News. (2022). *Gli hacker di Killnet minacciano l'Italia, poi si complimentano: siete stati bravi a difendervi*. Retrieved from https://www.rainews.it/articoli/2022/05/gli-hacker-di-killnet-minacciano-litalia-e-poi-si- complimentano-siete-stati-bravi-a-difendervi-5cef7429-d944-4612-875f-bcf74acd030e.html Accessed March 13, 2024.

Simone Busetti is an Associate Professor of Political Science and Public Policy at the Department of Political Science, University of Teramo. At present, he is coordinating the university team of the project "Cybersecurity (as a) public policy" funded by the Italian Ministry of Research. He recently coordinated the Erasmus + project "P-Cube" (2021−2023) to develop a digital game for teaching policy decisions. He has an extensive record of evaluation research for national and international funding bodies (e.g., Horizon 2020, ESPON EU). He is an expert in qualitative methods and process tracing for theory-based evaluation. He has published in leading journals such as Policy Sciences, Evaluation, Policy & Politics, Public Policy & Administration.

Francesco Maria Scanni is a Research Assistant at the University of Teramo. He is currently working on the project "Cybersecurity (as a) public policy" funded by the Italian Ministry of Research.